



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Transport Layer Security: SSL and TLS

materials are partly from security courses at other institutions



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

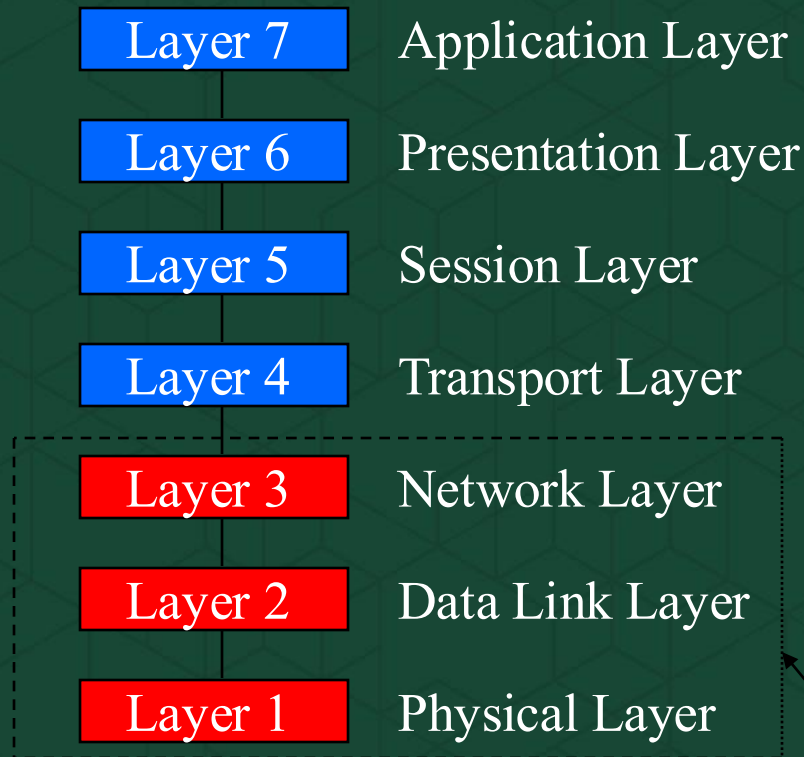
OSI Model

- OSI Reference Model - internationally standardised network architecture.
- OSI = *Open Systems Interconnection*: deals with *open systems*, i.e. systems open for communications with other systems.
- Specified in ISO 7498.
- Model has 7 layers.

7-Layer OSI Model



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —



- Layers 1-4 relate to communications technology.
- Layers 5-7 relate to user applications.

Communications subnet boundary

Internet Protocols vs OSI



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
ROLLA, MISSOURI

Application	Application
Presentation	
Session	
Transport	TCP
Network	IP
Data Link	Network Interface
Physical	Hardware

- Explicit Presentation and session layers missing in Internet Protocols
- Data Link and Network Layers redesigned



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

What Is SSL / TLS?

- Secure Sockets Layer and Transport Layer Security protocols
 - Same protocol design, different crypto algorithms
- **De facto standard for Internet security**
 - “The primary goal of the TLS protocol is to provide privacy and data integrity between two communicating applications”
- Deployed in every Web browser; also VoIP, payment systems, distributed systems, etc.

SSL / TLS Guarantees



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- End-to-end secure communications in the presence of a **network attacker**
 - Attacker completely owns the network: controls Wi-Fi, DNS, routers, his own websites, can listen to any packet, modify packets in transit, inject his own packets into the network
 - Including man-in-the-middle
- Scenario: you are reading your email from an Internet café connected via a rooted Wi-Fi access point to a dodgy ISP in a hostile authoritarian country

History of the Protocol

- SSL 1.0 – internal Netscape design, early 1994?
 - Lost in the mists of time
- SSL 2.0 – Netscape, Nov 1994
 - Several weaknesses
- SSL 3.0 – Netscape and Paul Kocher, Nov 1996
- TLS 1.0 – Internet standard, Jan 1999
 - Based on SSL 3.0, but not interoperable (uses different cryptographic algorithms)
- TLS 1.1 – Apr 2006
- TLS 1.2 – Aug 2008
- TLS 1.3 – draft as of Mar 2018.



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

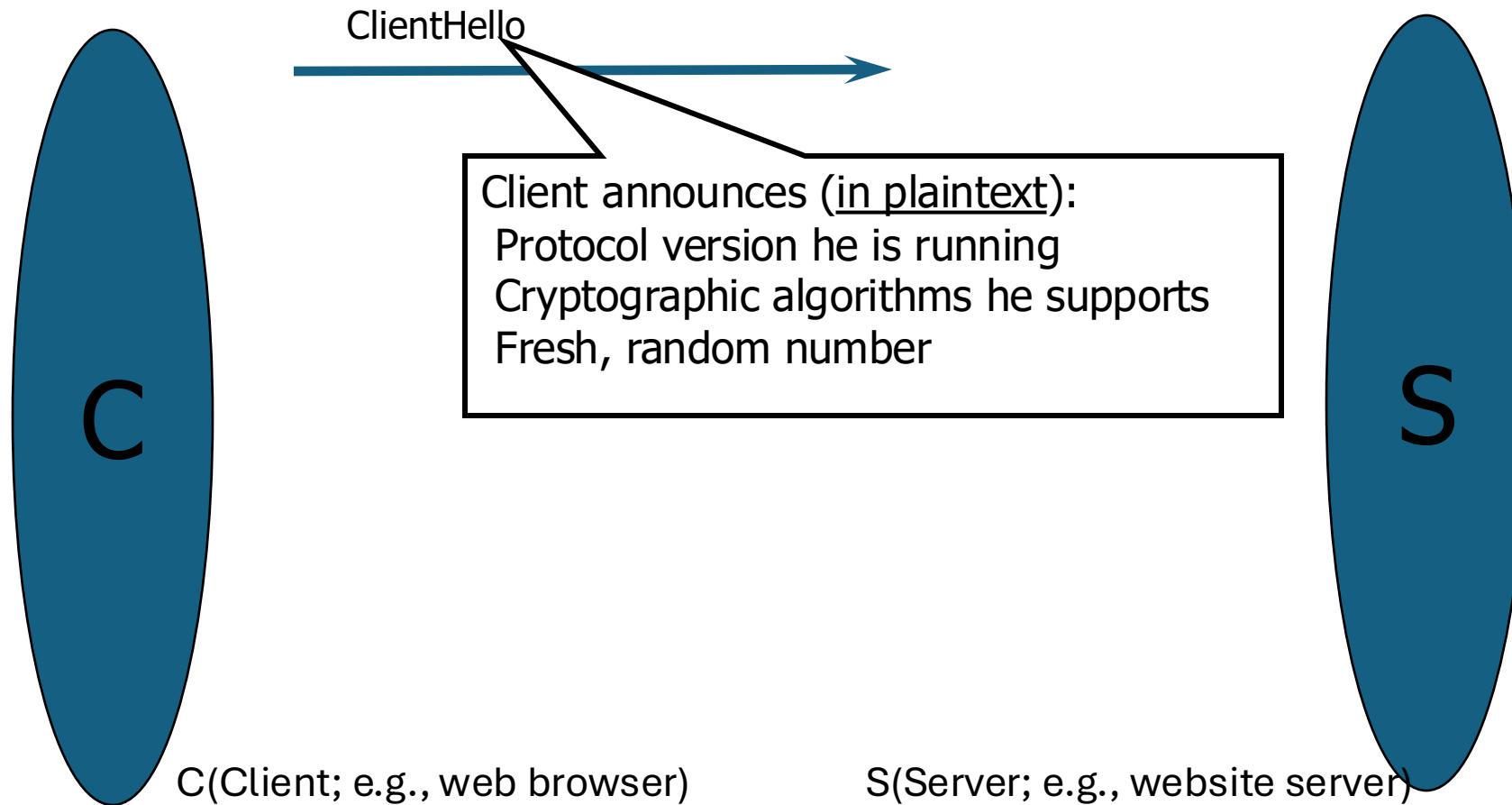
SSL Basics



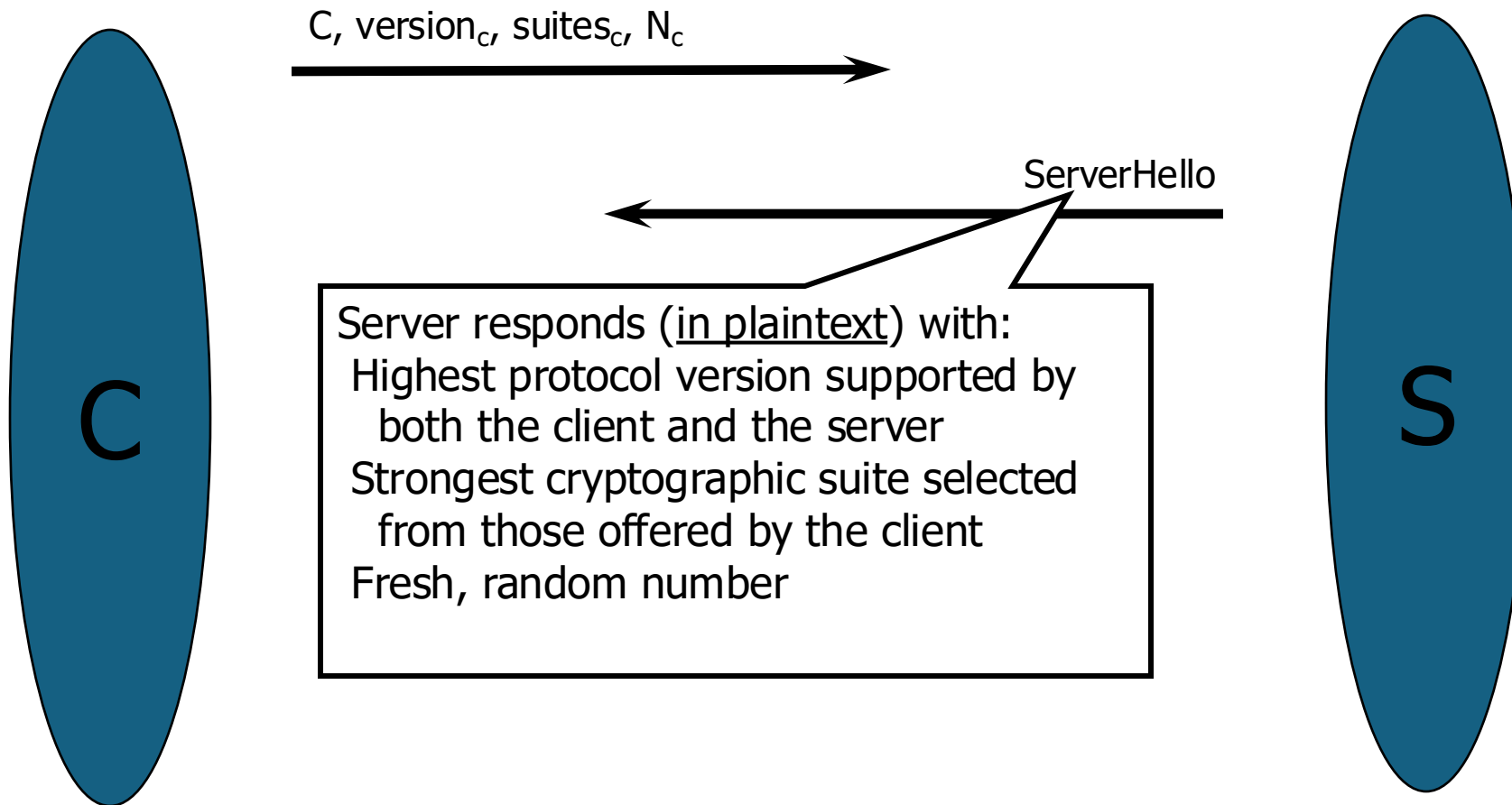
MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- SSL consists of two protocols
- Handshake protocol
 - Uses public-key cryptography to establish several shared secret keys between the client and the server
- Record protocol
 - Uses the secret keys established in the handshake protocol to protect confidentiality, integrity, and authenticity of data exchange between the client and the server

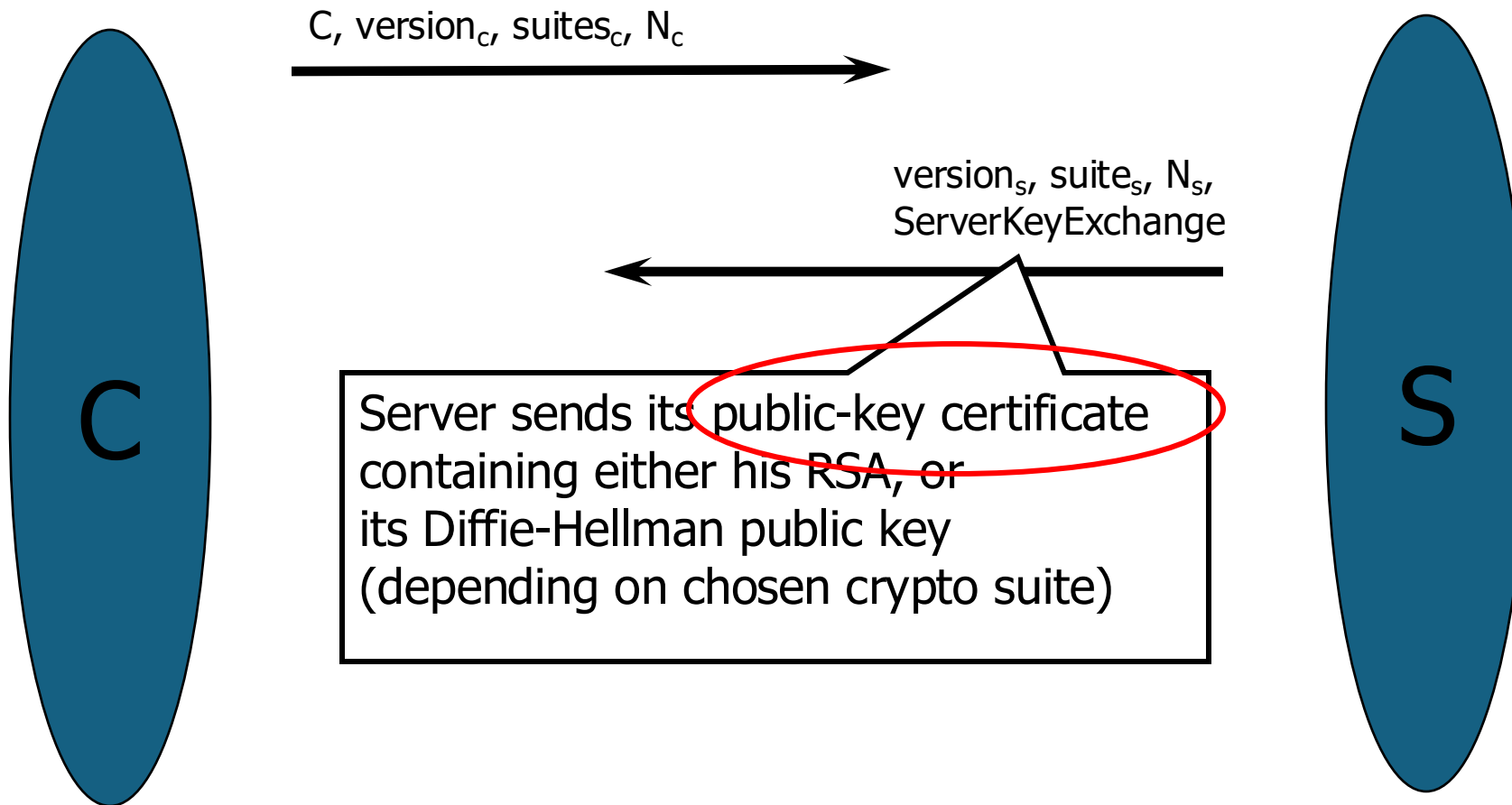
Client Hello



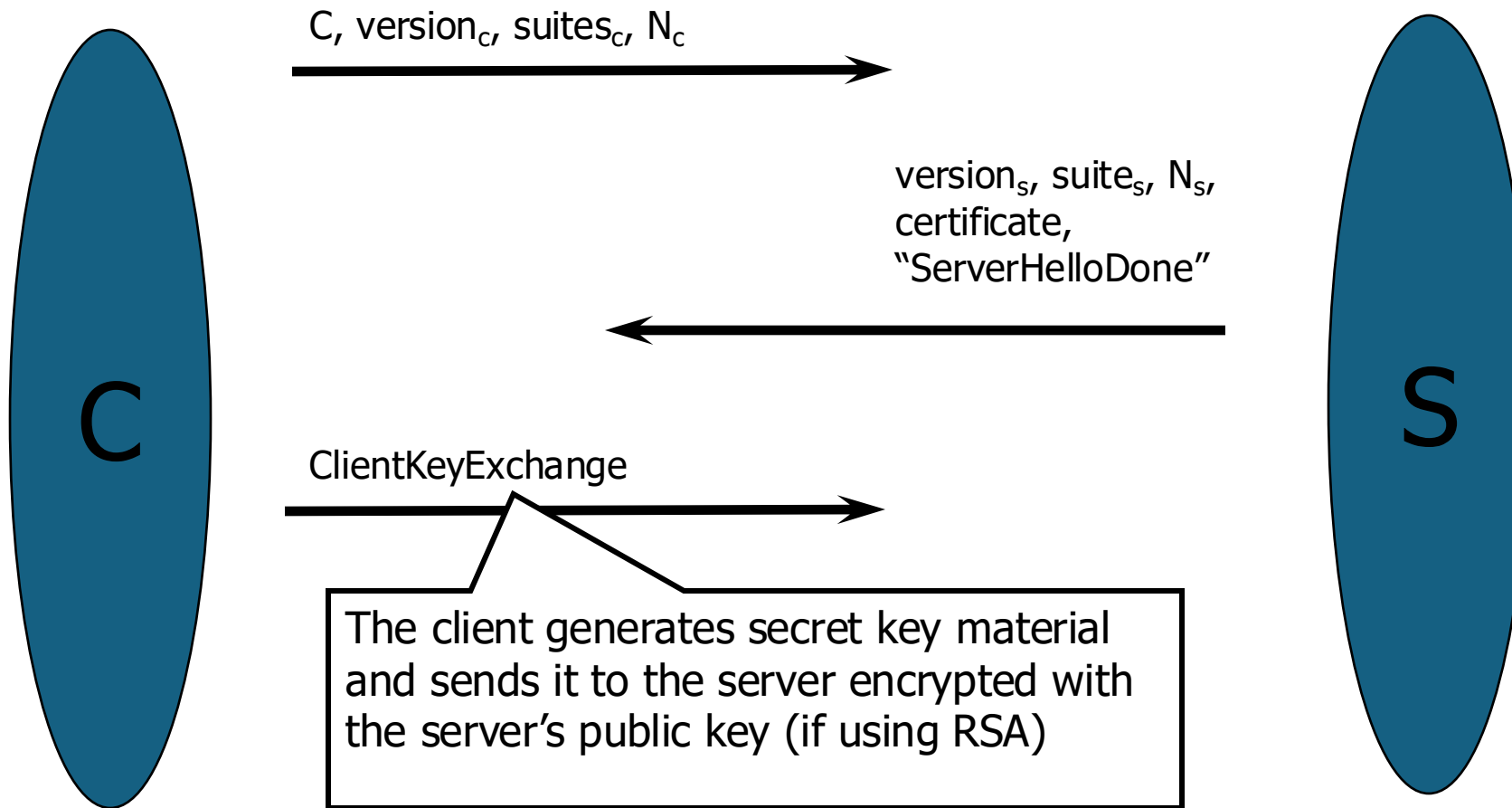
Server Hello



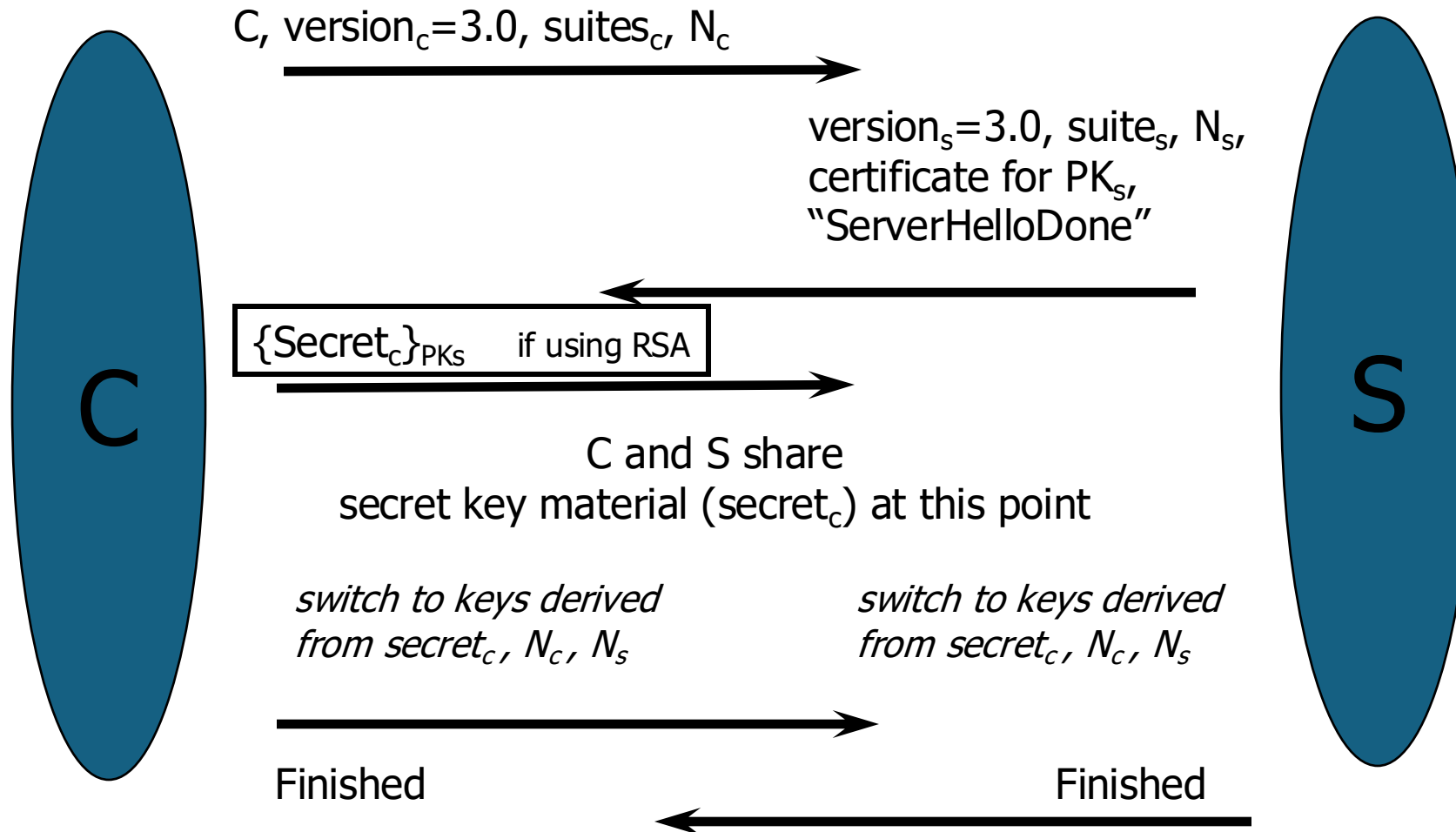
Server Key Exchange



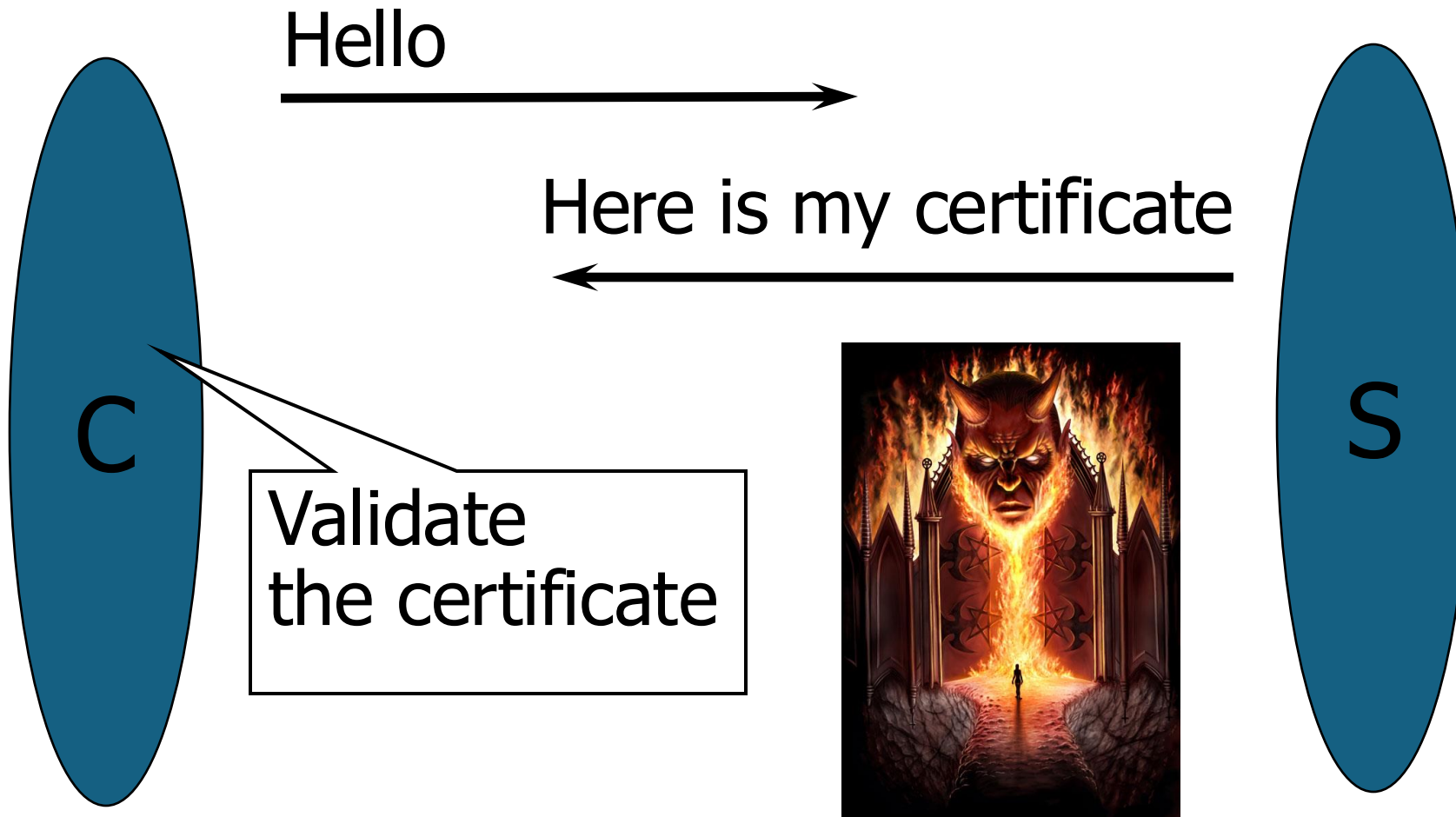
Client Key Exchange



“Core” SSL 3.0 Handshake



SSL/TLS Handshake



Check Everything in Certificate



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- A certificate includes important information
 - Server's public key
 - Domain name
 - Issuer
 - Expiration date
 - ...
- Must verify everything!

SSL/TLS Handshake: Attack Examples



Failing to Check Hostname



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
ROLLA, MISSOURI

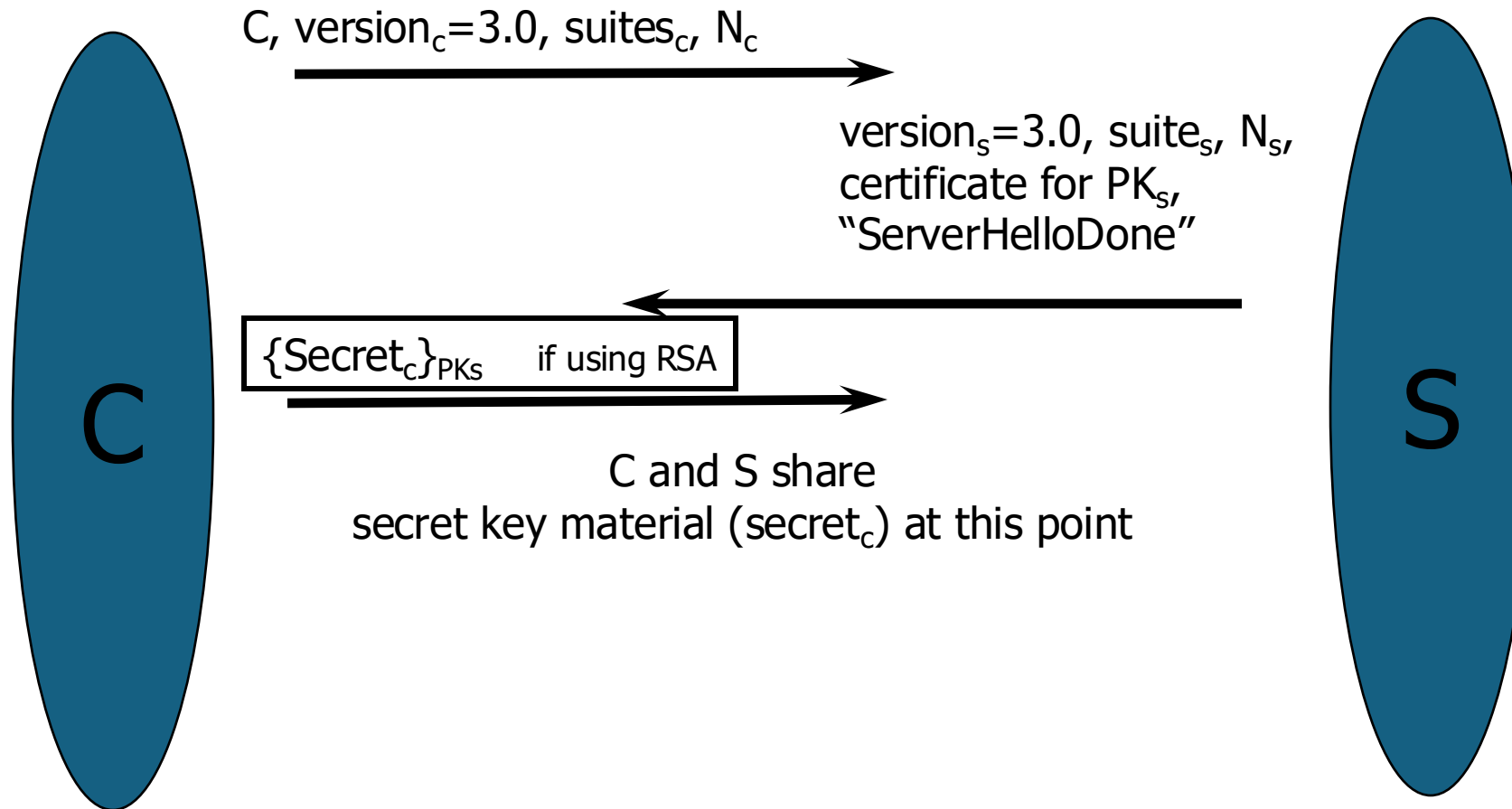
“Researchers at the University of Texas at Austin and Stanford University have discovered that poorly designed APIs used in SSL implementations are to blame for vulnerabilities in many critical non-browser software packages. Serious security vulnerabilities were found in programs such as Amazon’s EC2 Java library, Amazon’s and PayPal’s merchant SDKs, Trillian and AIM instant messaging software, popular integrated shopping cart software packages, Chase mobile banking software, and several Android applications and libraries. **SSL connections from these programs and many others are vulnerable to a man in the middle attack...**”

- Threatpost (Oct 2012)

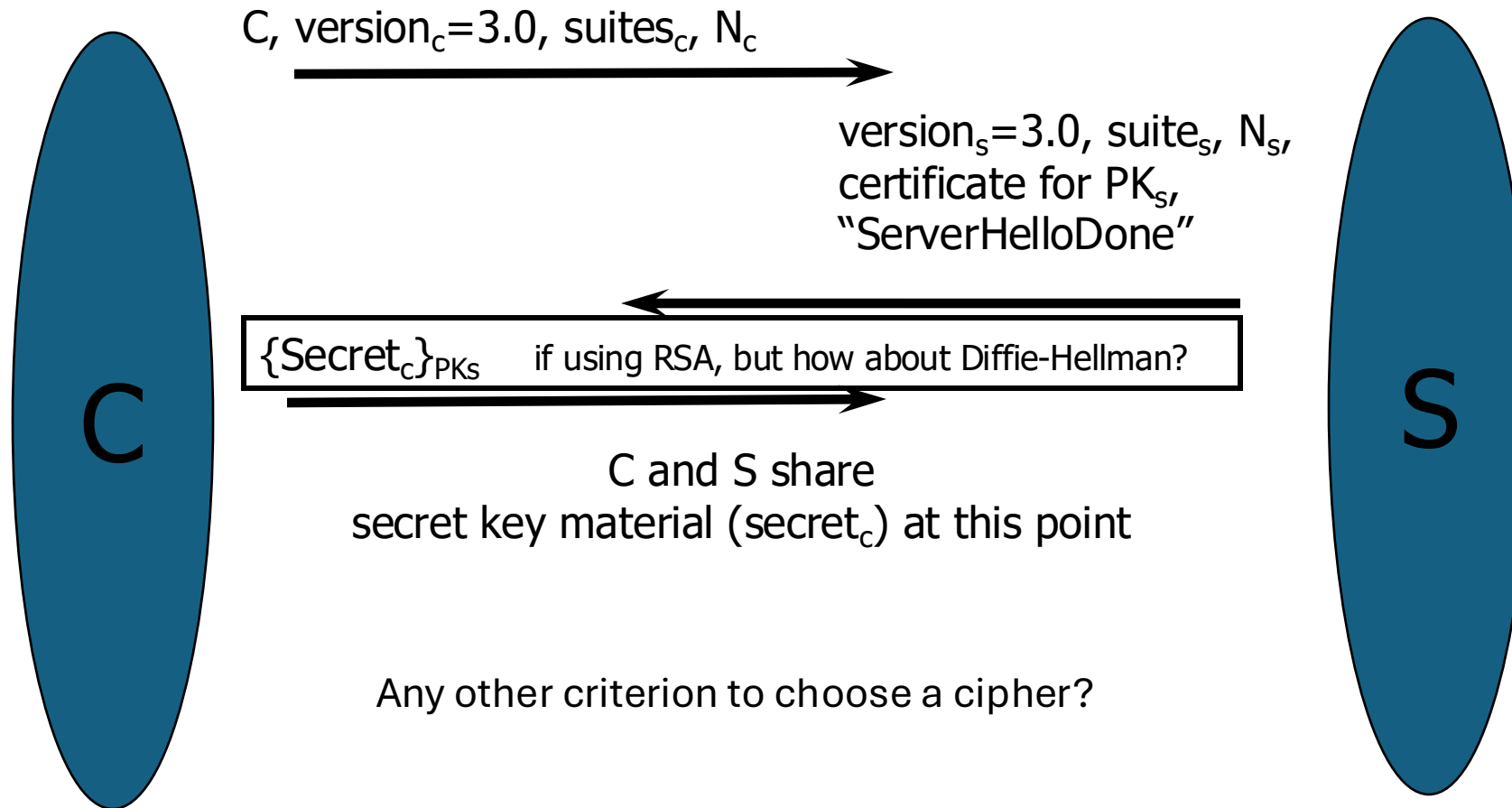


Major payment processing gateways,
client software for cloud computing,
integrated e-commerce software, etc.

“Core” SSL 3.0 Handshake



How to choose the Cipher?



Recall: RSA for Key Negotiation

Alice



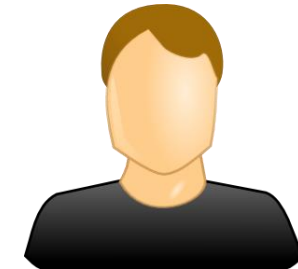
Public key: $K_{a,p}$
Private key: $K_{a,i}$

Generate random
number $R1$

Send $R1$ encrypted using $K_{b,p}$

1) get $R2$
2) get symmetric key
as $K = H(R1 \oplus R2)$,

Bob

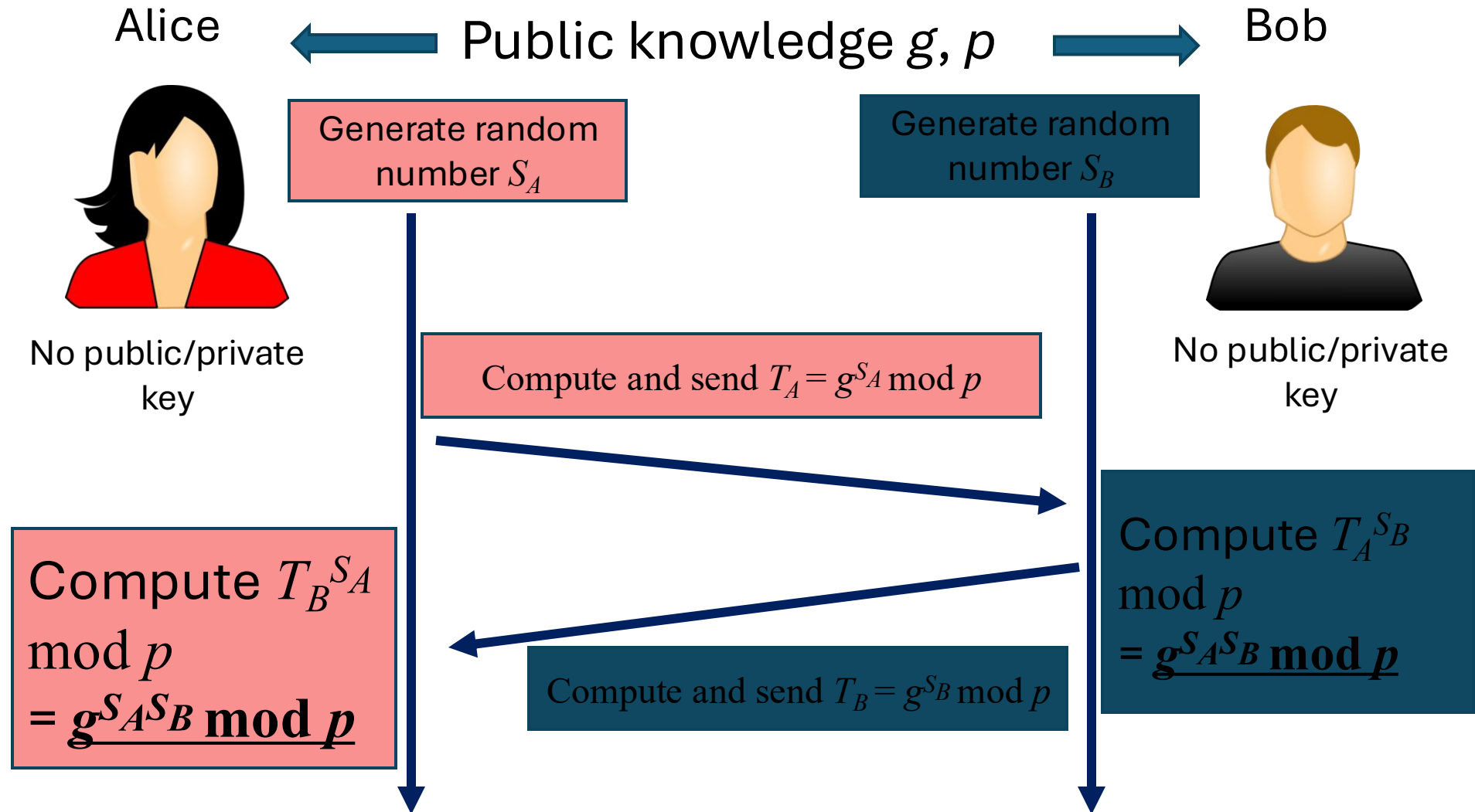


Public key: $K_{b,p}$
Private key: $K_{b,i}$

1) Get $R1$,
2) Generate random
number $R2$,
3) get key as
 $K = H(R1 \oplus R2)$,

Send $R2$ encrypted using $K_{a,p}$

Recall: D-H for Key Negotiation



Comparisons

- RSA vs Diffie-Hellman for key negotiation
- Security strength?
 - Billions/trillions years of cracking
- Other criterion of comparison?



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

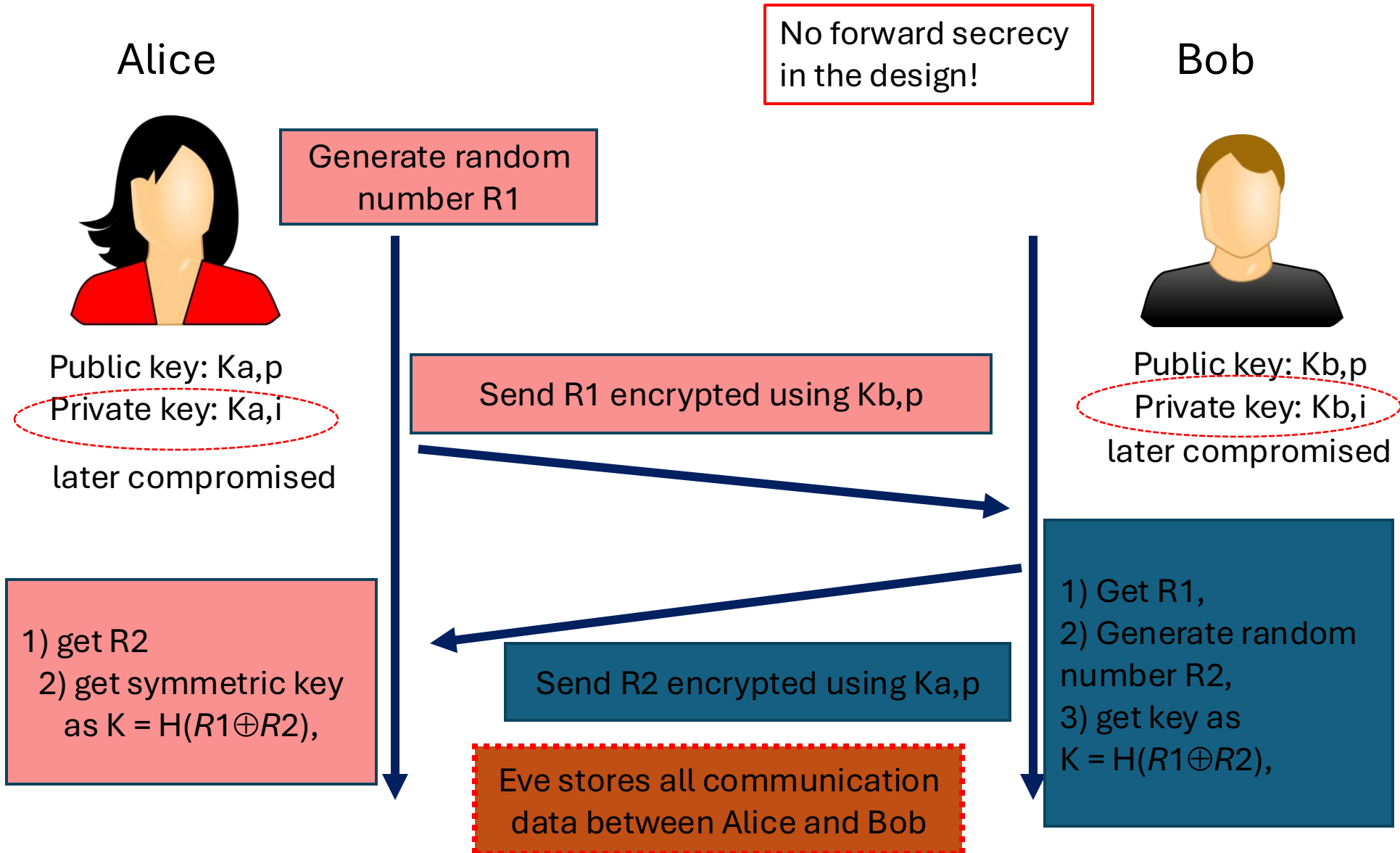
Forward Secrecy



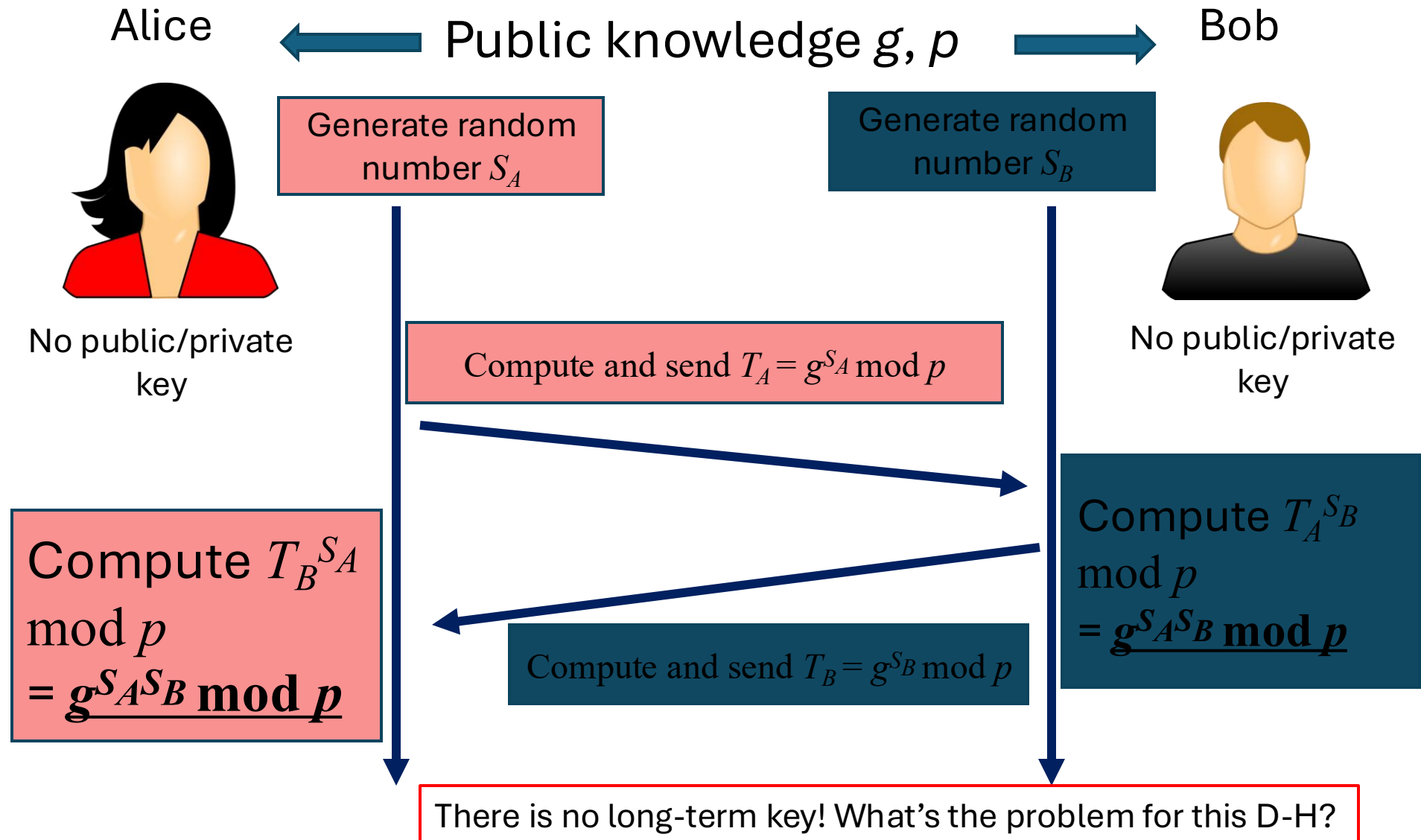
MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Also known as perfect forward secrecy
 - Vs. perfect secrecy
- Definition:
 - “Assurance that session keys will not be compromised even if long-term secrets used in the session key exchange are compromised”

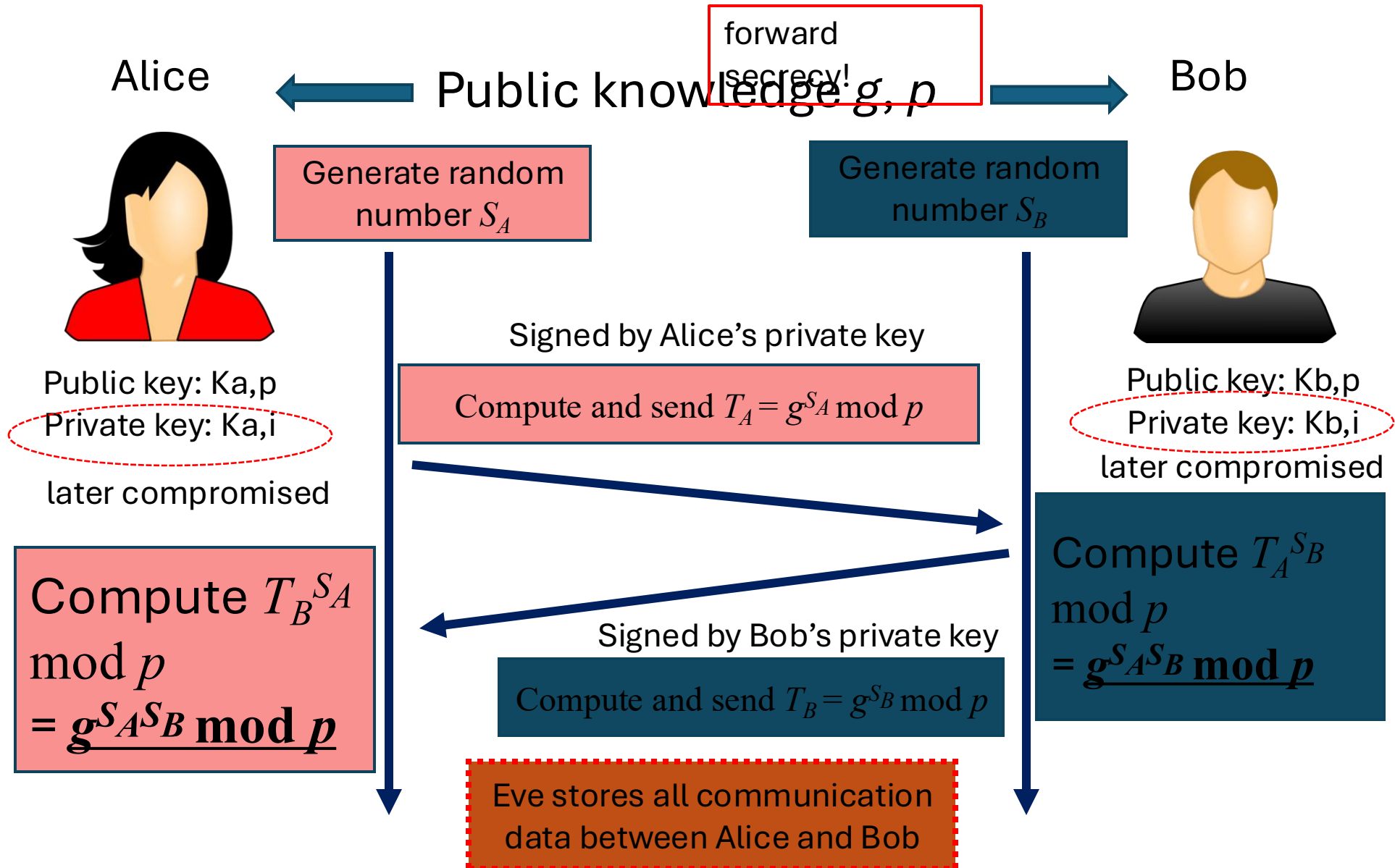
Private Keys compromised



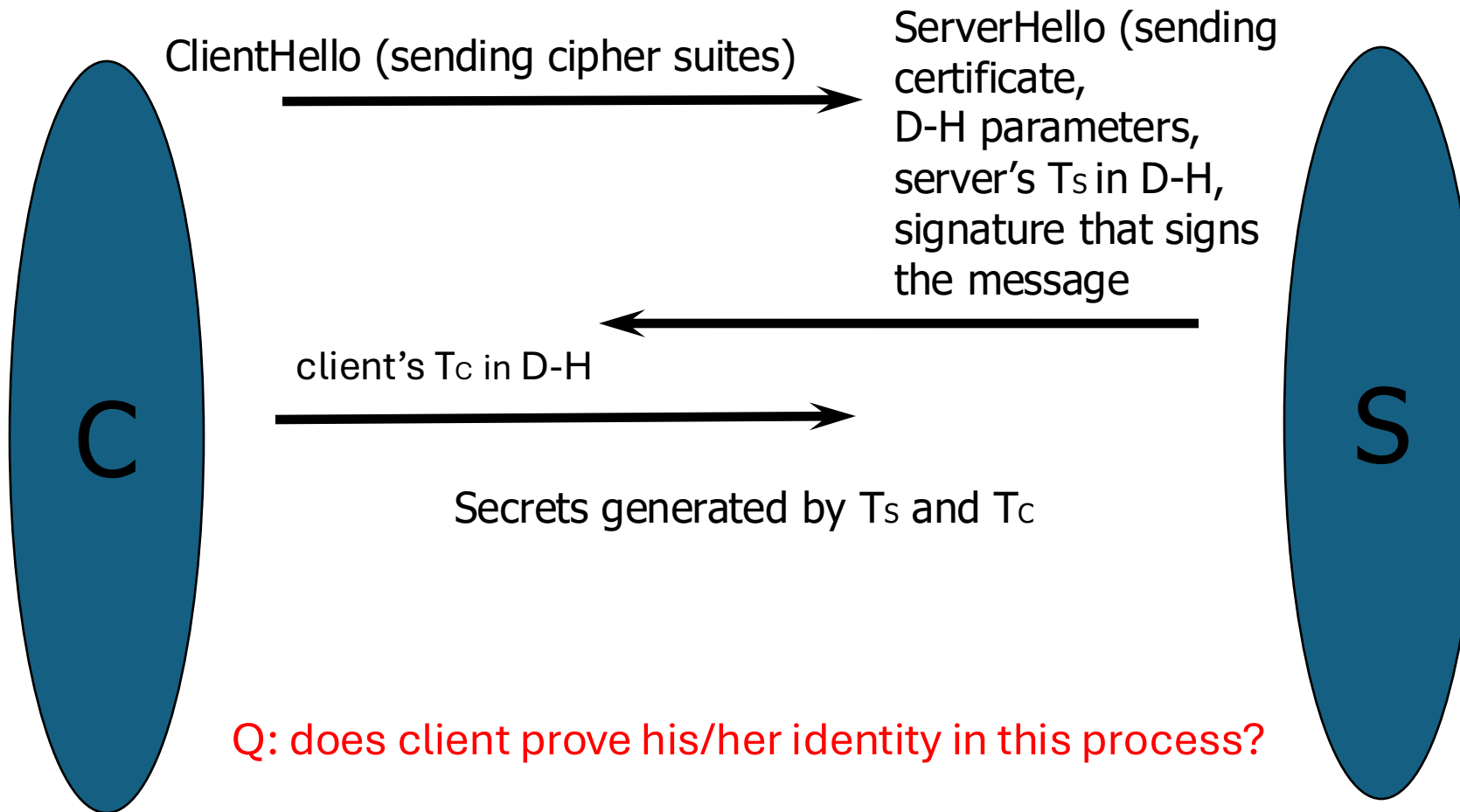
How about D-H?



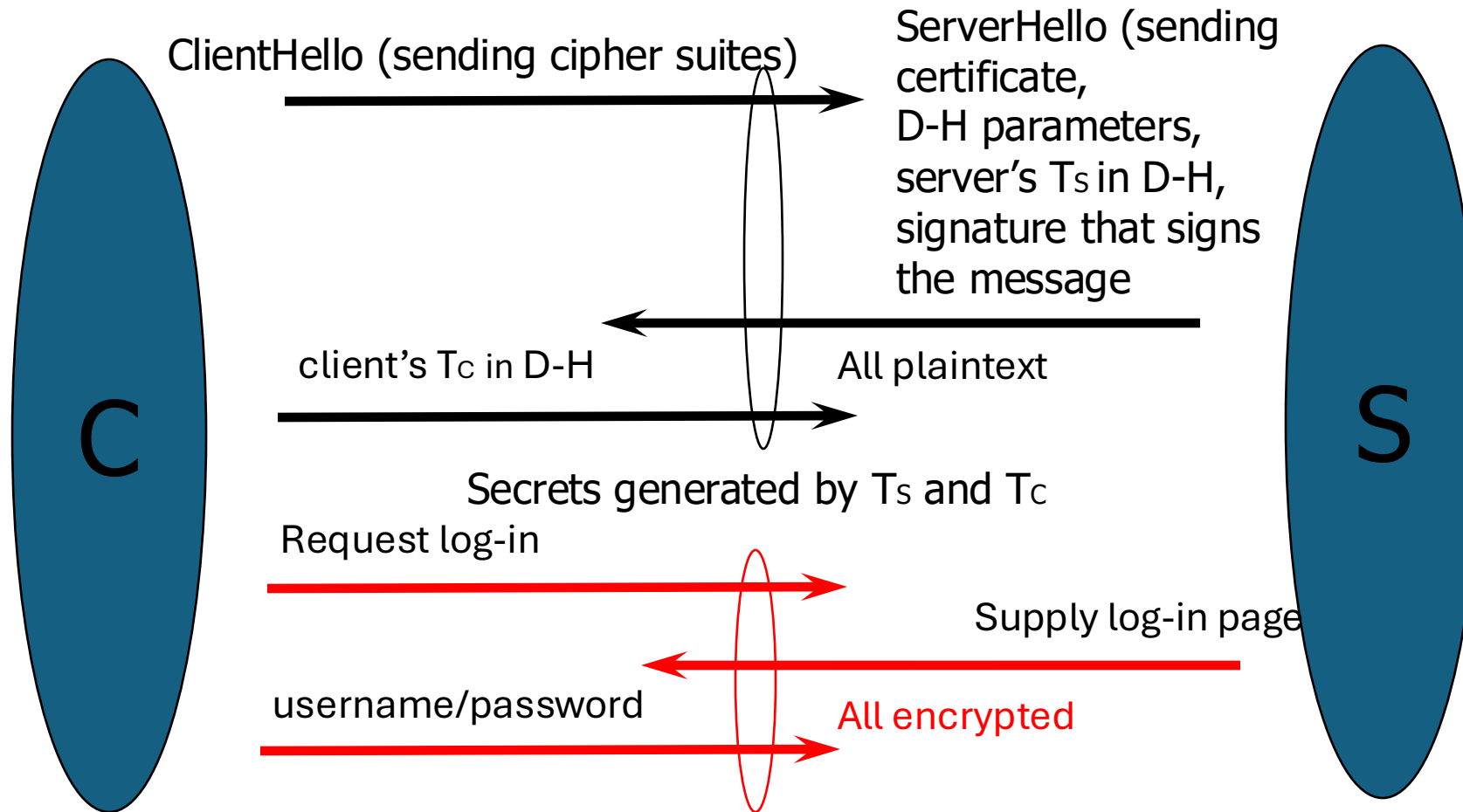
Need to use Authenticated D-H



TLS Process: Basic Example



How client proves him/her-self



Q: If Eve stores all the communication data and later obtains the server's private key, can Eve know the user's name and password?

Summary



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- SSL/TLS is the de facto authentication/encryption protocol standard for HTTP
 - becoming popular for many other protocols as well
- Allows negotiation of cryptographic methods and parameters
- Perfect forward secrecy